

Báo cáo tuần W1

Họ tên : Nguyễn Xuân Bách

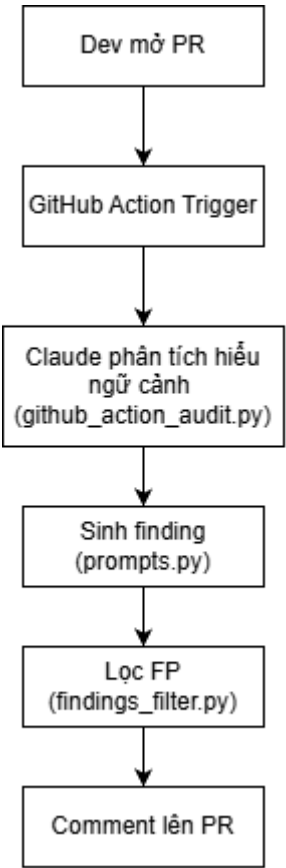
1. Khảo sát hiện trạng

STT	Vấn đề	Hệ quả
1	Fortify báo sai nhiều	Dev bỏ qua cảnh báo, công cụ thành thủ tục hình thức
2	Không thấy lỗi phụ thuộc ngữ cảnh nghiệp vụ	Lỗi phân quyền, lỗi logic
3	Chưa có benchmark chuẩn	Không đo được hiện trạng nên không có mốc so sánh

2. Nghiên cứu 2 repo

a. Claude-code-security-review

Đây là công cụ GitHub Action dùng Claude để tự động review bảo mật cho PR.



Bước	Đầu vào	Đầu ra
1. Developer mở PR	Code thay đổi trên branch (chưa merge)	Sự kiện PR (opened/synchronize) + commit SHA — kích hoạt workflow
2. GitHub Action trigger	Sự kiện PR, security.yml, quyền	Mã nguồn đã checkout + diff (unified diff) giữa

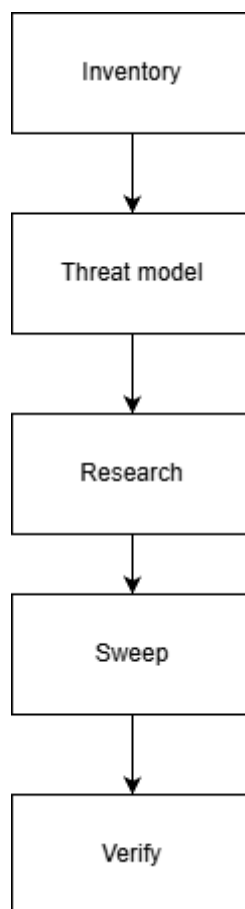
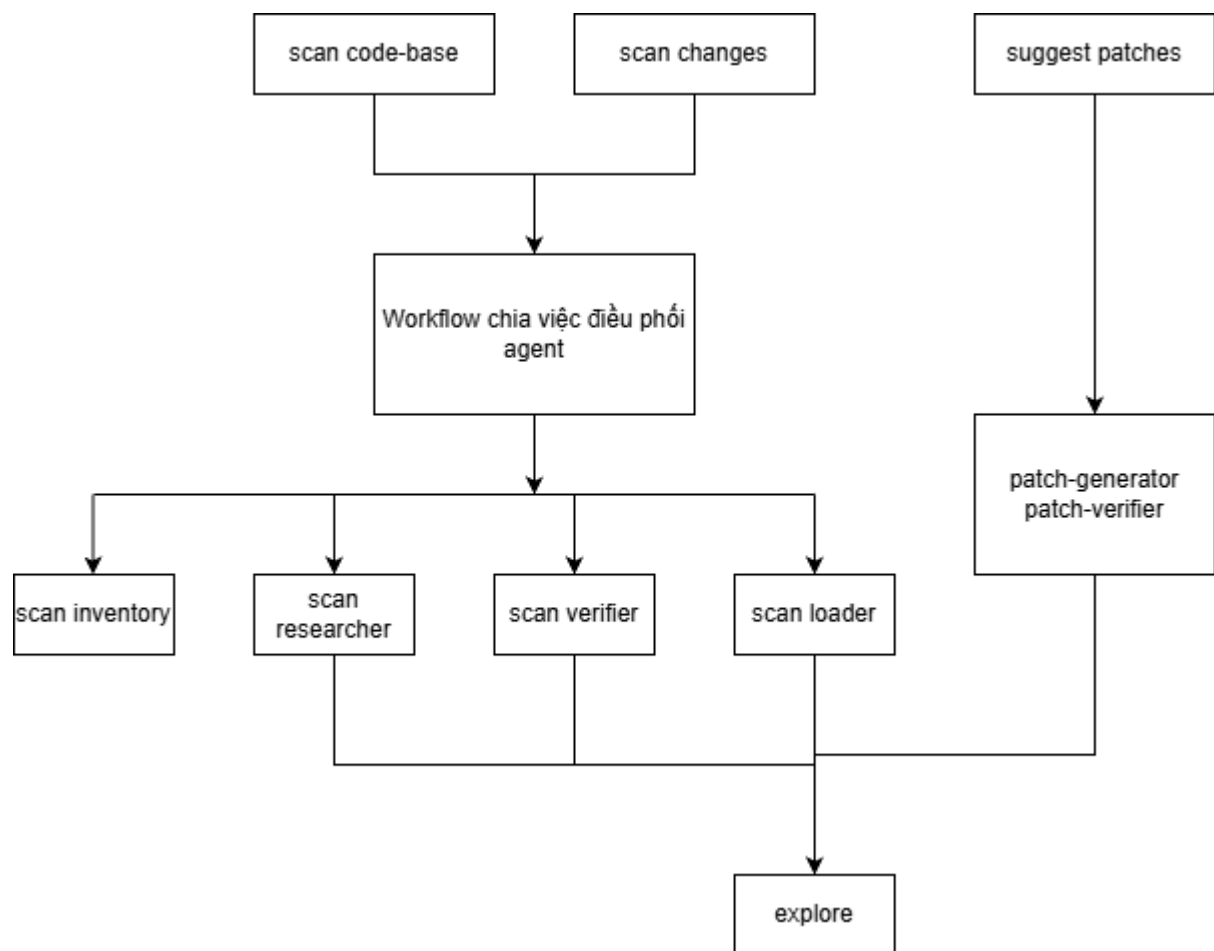
	contents: read, pull-requests: write	branch hiện tại và base
3. Claude phân tích diff (github_action_audit.py)	Diff + prompt audit từ prompts.py + claude-api-key	Phân tích ngữ nghĩa dạng text: đoạn nào nghi vấn, vì sao, luồng dữ liệu ra sao
4. Sinh finding (prompts.py)	Kết quả phân tích ở bước 3	Danh sách finding thô dạng JSON: file, line, severity, description, remediation (qua json_parser.py)
5. Lọc false positive (findings_filter.py, claude_api_client.py)	Danh sách finding thô	Danh sách finding đã lọc (loại DoS, rate-limit, open redirect, validate chung chung...)
6. Comment PR	Danh sách finding đã lọc	Comment trên PR + file results-file (JSON) + output findings-count

b. Claude-security plugin

Plugin cài vào Claude Code, chạy cục bộ trong session, dùng multi-agent (nhiều Claude agent phối hợp) để quét sâu.

3 chế độ :

Chế độ	Mô tả	Khi dùng
Scan codebase	Quét toàn bộ repo hoặc một vùng chọn (ví dụ tầng API, module auth)	Audit định kỳ, trước release
Scan changes	Chỉ quét diff của 1 branch, 1 PR, hoặc 1 commit cụ thể (cần Git, chỉ quét phần đã commit)	Kiểm tra trước khi merge
Suggest patches	Biến các finding đã chọn thành patch	Sau khi đã có báo cáo từ 2 chế độ trên



1. scan-inventory

Công việc	Chia repo thành các component
Tool	Read, Glob, Grep
Input	scanRoot; số file tracked; cap số component; kích cỡ component nhắm tới (~25 file); danh sách top-level dir (bọc <untrusted-directories>); số file mỗi dir (bọc <untrusted-directory-sizes>); scope; focus
Output	{ components: [{name, paths[], language, role?, internetFacing?}], securityScanSkippedComponents: [{name, paths[], reason}] }

2. scan-researcher

Công việc	Tìm lỗ hổng
Tool	Read, Glob, Grep, Bash, Agent(claude-security:explore)
Input	Tuỳ vai — xem Bảng 2.1
Output	Tuỳ vai — xem Bảng 2.1. Cấu trúc một finding xem Bảng 2.2

Bảng 2.1 — Bốn vai của scan-researcher

Vai	Input riêng	Output
Threat model (xác định mối nguy)	1 component: name, paths, language, role	{entryPoints[], sinks[], assumptions[], trustBoundaries[], hotFiles[]} — tất cả dạng file:line.
Research (đi tìm lỗi)	1 component + 1 category lens + threat model của component đó	{findings[], coverage: {filesRead[], notReached[{path, why}]}}
Sweep (vét)	Danh sách path đã quét của researcher	{findings[]}

Bảng 2.2 — Cấu trúc một finding

Trường	Bắt buộc	Mô tả
file	có	Đường dẫn tương đối so với scan root
line	có	Đúng dòng sink
cweId	có	Một mã CWE cụ thể nhất, khớp ^CWE-[1-9][0-9]{0,4}\$
severity	có	CRITICAL HIGH MEDIUM LOW
confidence	có	HIGH MEDIUM LOW — độ chắc, KHÔNG phải mức nguy hiểm
title	có	Một dòng
rationale	có	1–2 câu nêu nguồn không tin cậy và sink nguy hiểm
evidence	—	Tối đa khoảng 10 dòng code trích dẫn

snippet	—	Dòng sink, nguyên văn — dùng để neo lại finding khi dòng dịch
symbol	—	Hàm / method bao quanh
impact, exploitScenario, preconditions, recommendation	—	Bổ sung cho báo cáo

3. scan-verifier

Công việc	Nhận 1 candidate finding và 1 nhiệm vụ: cố bác bỏ nó. Finding chỉ giữ lại nếu verifier thất bại.
Tool	Read, Glob, Grep, Bash, Agent(claude-security:explore)
Input	1 candidate bọc trong <untrusted-finding> (file, line, cweId, severity, title, rationale, evidence, snippet, symbol, số researcher pass đã báo độc lập)
Output	{ verdict: "TRUE_POSITIVE" "FALSE_POSITIVE", reasoning: "1-2 dòng nêu file:line quyết định", severity?: "CRITICAL HIGH MEDIUM LOW" }

4. scan-loader

Công việc	Đọc 1 file candidates trong run dir và trả nội dung JSON y nguyên.
Tool	Read
Input	1 tên thư mục + 1 tên file (candidates.<shard>.<chunk>.json)
Output	{ runDir, shard, chunk, candidates: [finding + {cid: "C<n>", reports}] }

5. explore

Công việc	Tìm và đọc code, được AGENT KHÁC gọi khi cần định vị file, truy một luồng chạy qua nhiều file.
Tool	Read, Glob, Grep, Bash
Input	1 câu hỏi + độ sâu mong muốn ("quick" / "medium" / "very thorough")
Output	Văn xuôi, không có schema: câu trả lời trực tiếp trước → dẫn chứng path/to/file.ext:line

6. claude-security (Security Lead — điều phối)

Công việc	Nhận một job chạy, điều phối
Tool	Read, Glob, Grep, Bash, Write, Edit, AskUserQuestion, Workflow,

	Workflow(claude-security:scan), TaskCreate / TaskGet / TaskList / TaskUpdate / TaskOutput / TaskStop, Agent(scan-inventory, scan-researcher, scan-verifier, scan-loader, patch-generator, patch-verifier, explore)
Input	Yêu cầu của user + repo mà phiên đang mở. initialPrompt "/claude-security:claude-security" tự nạp role file ngay lượt đầu.
Output	Thư mục CLAUDE-SECURITY- <code><ts></code> / gồm báo cáo MD, JSONL, SARIF, revision stamp; tùy chọn thư mục patches/; và một đoạn báo cáo bằng lời cho user.

7. patch-generator

Công việc	Cài đặt bản vá cho 1 finding bên trong một workspace scratch
Tool	Read, Glob, Grep, Bash, Edit, Write, Agent(claude-security:explore)
Input	FINDING (object finding, trường file đã đổi sang repo-root-relative), WORKSPACE (đường dẫn tuyệt đối), SCAN_ROOT (tuyệt đối)
Output	{ summary: "nguyên nhân gốc + bản vá làm gì", changedFiles: [...] } hoặc { refusal: "lý do" }

8. patch-verifier

Công việc	Chấm 1 bản vá đã cài: xem staged diff, chạy test của project, quyết định nó có đủ an toàn để thành file patch trên đĩa người dùng không.
Tool	Read, Glob, Grep, Bash, Agent(claude-security:explore) — KHÔNG có Edit, KHÔNG có Write
Input	FINDING, WORKSPACE, SCAN_ROOT
Output	{ verdict: "PASS" "REJECT", claims: { TARGETED, NO_NEW_VULNERABILITY, BEHAVIOUR_UNCHANGED }, untested: bool, REVIEWED_PATHS: [...], testsRun: "lệnh nguyên văn" "none possible + lý do", objections: [...] }